

大数据安全课后题

教材课件配套的习题作业

第一章

填空题

- 2018年5月25日，GDPR在欧洲全面实施。
- 我国颁布数据安全方面两部基础性法律：数据安全法；个人信息保护法
- 数据是数字经济时代核心生产要素。
- 隐私保护：用户数据的机密性和用户行为数据的不可区分性，即对用户元数据的保护。

简答题

- 安全和隐私的区别：
 - 安全：聚焦数据资产的保密性、完整性、可用性（CIA 三要素），防范未授权访问、篡改或破坏。
 - 隐私：侧重个人对自身数据的控制权，确保个人身份、行为等敏感信息不被非法收集、使用或泄露，核心是个人自主性保护。
- 个人数据安全和个人隐私的关系：
 - 数据安全是隐私保护的基础：通过加密、访问控制等技术手段保障个人数据不被泄露或滥用；隐私是数据安全的最终目标之一：数据安全措施（如匿名化）需服务于隐私保护，但隐私还涉及法律合规（如知情同意）。
- 技术进步和隐私保护的关系：
 - 技术进步威胁隐私：大数据分析、人脸识别等技术加剧个人信息滥用风险。
 - 技术增强隐私保护：差分隐私、联邦学习、同态加密等技术实现“数据可用不可见”，提升隐私防护能力。
 - 动态平衡：法律法规（如 GDPR）要求技术研发内嵌隐私保护机制。

第二章

- 完善保密加密的概念：
 - 完善保密加密指密文不泄露任何明文信息的加密方案。即使攻击者拥有无限计算资源，也无法从密文中推断明文（即明文与密文独立 $P(M = m|C = c) = P(M = m)$ ）。
- 设计密码算法的启发式方法：
 - 混淆（非线性变换），扩散（将明文/密钥的局部变化扩散到整个密文），迭代结构（多轮重复简单操作提升安全性）等。
- 香农乘积密码设计思想：

- 将多个简单的密码变换（如代换和置换）组合，形成复杂的整体结构，提高安全性。
基本原理：单一变换容易被破解，组合变换可指数级增加攻击难度。典型实现：DES（Feistel 结构，S 盒 + P 盒）；AES（多轮代换、行移位、列混合、轮密钥加）。
- 分组密码工作模式选择原则：
 - 满足安全性需求：不同模式安全特性不同，如 CBC 可隐藏明文模式，ECB 不可。
 - 适应数据特性：流式数据常用 CFB/OFB/CTR；存储数据可用 CBC。
 - 错误传播控制：对错误敏感度有要求时避免使用错误扩散严重的模式。
 - 并行处理能力：CTR、GCM 支持并行加解密；CBC 加密不可并行。
 - 附加功能：如需要完整性验证可选择带认证的模式（GCM、CCM）。
- 简述利用生日攻击的方法攻击哈希函数的过程：
 - 基于生日悖论：在 n 位哈希中，仅需约 $2^{n/2}$ 次尝试就可能找到碰撞。
 - 攻击步骤：
 - 生成大量随机消息并计算哈希值。
 - 比较结果，寻找相同哈希值的不同消息。
 - 若找到碰撞，可用于伪造签名或破坏完整性验证。
 - 例：对 128 位哈希，碰撞复杂度仅约 2^{64} 次运算。

第三章

填空题

- TLS协议分为：握手阶段；安全通信阶段
- TLS使用 DHE 算法 保证前向安全性。
- HMAC工作原理：H(K XOR opad||H(K XOR ipad||text))
- 采用HSTS策略的网站将保证浏览器始终连接到网站的 HTTPS 加密版本。
- DLTS提供与TLS近似加密保障，但是保留了底层高效的 UDP 的传输机制。

选择题

- TLS握手协议任务：A协商密钥规格B利用公钥证书来认证服务器身份C生成会话密钥
- HTTPS部署模式最安全的是DHTTPS+HSTS Preload
- 解决仿冒证书问题A.CT

术语解释

- HSTS（HTTP Strict Transport Security，HTTP 严格传输安全）是 IETF 发布的一种互联网安全策略机制。采用 HSTS 策略的网站将保证浏览器始终连接到该网站的 HTTPS 加密版本，不需要用户手动在 URL（统一资源定位符）地址栏中输入加密地址，以减少会话劫持风险。
- 内容分发网络（Content Delivery Network，CDN）是一种分布式基础设施，可以有效地向最终用户提供网站的内容。

简答题

- TLS 1.3 握手流程改进点：
 - 减少往返次数：TLS 1.3 将握手从 2-RTT 缩减为 1-RTT，支持 0-RTT。
 - 移除不安全算法：去掉 RSA、静态 DH 握手，只保留 ECDHE 提供前向安全性。
 - 加密范围扩大：握手消息更早进入加密状态，减少被窃听风险。
 - 性能提升：更快的握手与更强的安全性。
- HSTS Preload作用与原理：
 - 作用：让浏览器在首次访问网站时也强制使用 HTTPS，避免第一次连接被劫持。
 - 原理：网站管理员向浏览器厂商提交域名，浏览器内置一份“预加载列表”，用户访问该域名时直接走 HTTPS。
- Web PKI 工作原理：基于数字证书与信任链：
 - 浏览器内置根证书。
 - 服务器证书由受信任 CA 签发。
 - 客户端通过验证证书链确保服务器身份合法。从根证书 → 中间证书 → 网站证书逐级验证，建立信任。
- ACME 协议工作原理：是自动化证书管理协议（由 Let's Encrypt 推广）。工作流程：
 - 客户端向 CA 请求证书。
 - CA 验证域名所有权（DNS 记录/HTTP 文件验证）。
 - 验证通过后，自动签发证书。
 - 客户端定期通过 ACME 自动续期证书。
- CT和PKP工作原理：
 - 证书透明度（CT）：所有证书必须公开记录到透明日志（不可篡改的日志服务器）；浏览器检查证书是否在日志中，防止伪造或私签证书。
 - PKP（Public Key Pinning）：网站声明自己只接受特定公钥（Pin）；浏览器连接时必须匹配 Pin，否则拒绝连接；缺点：一旦配置错误可能导致网站“锁死”，因此现在较少使用。
- Noise VS. TLS：
 - Noise 协议框架：一个模块化的加密握手框架，可快速构建安全协议；轻量、灵活，广泛用于即时通讯（如 Signal）。与 TLS 的不同：
 - Noise 是框架，TLS 是固定协议。
 - Noise 没有 PKI 内置信任机制，而 TLS 依赖 Web PKI。
 - Noise 设计简洁，更适合小型应用；TLS 复杂，适合 Web 生态。

第四章

填空题

- 身份认证4个基本原语：口令；安全令牌；生物特征；公钥（证书）
- FIDO包含两套协议：UAF;U2F
- Kerberos的票据：票据许可票据；服务票据
- OAuth2.0 涉及的四角色：资源所有者；客户端；授权服务器；资源服务器
- OPAQUE可以抵抗：预计算攻击

选择题

- 68个可用字符，需要长度为C.21的口令达到128位安全
- 抵抗彩虹表攻击：A.PKDF2 B.BCRYPT C.SCRYPT
- 实现单点登录的协议：A.Kerberos B.OAuth C.OpenID Connect

术语解释

- MFA：多因子认证（Multi-Factor Authentication，MFA）是一种安全认证过程，需要用户提供两种及以上不同类型的认证因子来表明自己的身份，以便获得系统或设备的访问权限。它可以提高认证的安全性。
- Cookie：是存储在客户机上的文本文件。当用户浏览互联网时，服务器端的代码就可以在用户的计算机上创建一个很小的文本文件，称为 Cookie（小甜饼）。当该用户再次访问同一站点时，服务器就可以根据 Cookie 来识别该用户。

简答题

- 口令认证优缺点：
 - 优点：使用简单，用户易于理解和操作；部署成本低，不依赖额外硬件或复杂系统；普遍兼容，几乎所有系统和应用都支持。
 - 缺点：容易被弱口令、重复口令攻击；易遭受字典攻击、暴力破解、钓鱼攻击；难以抵抗中间人攻击和数据库泄露；用户记忆负担大，容易遗忘或写在不安全的地方。
- 硬件令牌/安全芯片优缺点：
 - 优点：私钥存储在硬件中（如智能卡、TPM、安全令牌），不易被导出，安全性高；提供强身份认证，抵御伪造和重放攻击；符合高等级安全要求，适用于金融、政务等场景。
 - 缺点：成本较高（硬件采购、管理、维护）；使用不够便捷，需要额外设备；硬件丢失或损坏会导致认证困难。
- FIDO 协议族：
 - FIDO UAF（Universal Authentication Framework）：无密码认证框架，用户通过生物特征（指纹、人脸识别）或本地 PIN 登录。
 - FIDO U2F（Universal Second Factor）：双因素认证方案，使用安全密钥（如 USB Key）作为额外因子，保护现有用户名+密码体系。
 - FIDO2：整合并扩展了 UAF 和 U2F，包括 WebAuthn API 和 CTAP 协议，支持无密码登录和强认证，兼容浏览器与平台。
 - 联系：FIDO2 是 UAF 与 U2F 的继承和发展；都基于公钥加密，强调“私钥在本地安全存储”；都不依赖传统密码，提升抗钓鱼能力。
- OAuth 2.0 与 OpenID Connect (OIDC)：
 - OAuth 2.0：授权协议，允许用户授予第三方应用访问资源服务器的权限，而无需暴露密码。例如允许第三方应用读取用户的谷歌相册。
 - OpenID Connect (OIDC)：建立在 OAuth 2.0 之上的身份认证层，增加了 ID Token，用于确认“用户是谁”。

- 区别：OAuth 2.0 解决“授权”问题，侧重资源访问控制；OpenID Connect 解决“认证”问题，侧重确认用户身份；OIDC 的流程在 OAuth 2.0 基础上增加了身份令牌的交换。
- Cookie 安全：
 - Cookie 存储用户的会话信息（如登录状态）。
 - 攻击者通过网络嗅探、中间人攻击、XSS 脚本注入等手段窃取 Cookie。
 - 一旦攻击者获取了有效 Cookie，就能伪装成用户，绕过登录过程，直接访问系统资源。
- OPAQUE 协议：
 - 提供了一种能抵抗预计算攻击的方法，是一种强 aPAKE 协议。
 - OPAQUE 协议通过把不经意伪随机函数（Oblivious Pseudorandom Function，OPRF）和 AKE 协议结合起来的这种方案构造。不经意伪随机函数是双方参与计算的一种方式，其中一方为计算提供输入，而另一方执行计算。“不经意”指的是协议性质，执行计算的一方对所提供的输入一无所知，而提供实际输入的一方只学习输出，而对计算没有任何了解。
 - OPAQUE 协议由三条消息组成，服务器和客户端分别需要三次和四次求幂，提供前向保密和显式相互认证，不需要 PKI，支持用户端密码强化，具有基于密码的存储和检索密钥和证书的内置功能，并适应一种用户透明的服务器端阈值实现。

第五章

填空题

- 云计算服务模式：SaaS;PaaS;IaaS
- 容器技术核心概念：镜像；容器；仓库
- 容器访问到外面的资源甚至获得宿主主机的权限：Docker 容器逃逸
- 英特尔CPU存在的漏洞具有两种攻击模式：Meltdown;Spectre
- 谷歌大数据处理系统的三项广为人知的云计算技术：MapReduce 计算架构；谷歌文件系统（GFS）；Bigtable 数据管理系统

选择题

- CPA定理指的是不能同时实现：A一致性B可用性C分区容错性
- ACID业务提供：A原子性B一致性C隔离性D持久性
- BASE模型中的BASE指：A基本可用B软状态C最终一致性

术语解释

- 沙箱容器：在主机操作系统和容器里面运行的应用程序之间提供一道安全的隔离边界。
- PIR: 私有信息检索（Private Information Retrieval，PIR）是指用户在不泄露自己查询信息给数据库的情况下，完成对数据库的查询操作。

简答题

- 虚拟机 (VM) 与容器 (Container):
 - 虚拟机 (VM): 通过 Hypervisor 虚拟化整个硬件环境, 每个 VM 拥有独立的操作系统内核, 资源隔离性强, 但启动慢、开销大。
 - 容器 (Container): 基于操作系统级虚拟化, 共享宿主机内核, 仅隔离用户空间, 启动快、占用资源少, 但隔离性弱于虚拟机。
- Docker 逃逸原因及应对:
 - 原因一: 软件漏洞。①由于内核漏洞引起的逃逸。因为 Docker 会直接共享宿主主机内核, 所以宿主主机的内核存在安全漏洞会一并影响 Docker 的安全, 从而造成 Docker 逃逸。②由于 Docker 软件设计引起的逃逸。
 - 原因二: 错误的配置。攻击者利用宿主机内核缺陷突破隔离。
 - 应对措施: 及时更新内核和容器运行时, 采用 SELinux/AppArmor 等安全机制。
- Meltdown 与 Spectre:
 - Meltdown: 利用乱序执行绕过内核与用户空间的隔离, 直接读取内核敏感数据。影响主要在 Intel CPU。
 - Spectre: 利用分支预测和投机执行误导程序, 跨越进程边界泄露数据。影响范围更广 (Intel、AMD、ARM)。
 - 区别: Meltdown 攻击更直接, 易修复; Spectre 攻击更复杂, 难以彻底消除。
- POR (Proof of Retrievability, 可检索性证明):
 - 一种远程数据完整性验证技术。
 - 基本原理:
 - 客户端在上传数据前生成认证标签/编码块。
 - 验证时, 服务器返回数据片段和认证信息。
 - 客户端通过验证证明服务器确实完整保存了数据, 而无需取回全部数据。
- 云存储隐私与去重:
 - 目标: 在云存储中既能保证隐私, 又能实现数据去重 (节省存储)。
 - 基本原理: 最早提出的方案是 CE: 当需要加密一个数据块 d 的时候, CE 先用数据内容生成密钥, 再用一个对称加密算法加密。(不够具体吗, 看PPT/书多抄点)

第六章

填空题

- 安全多方计算模型分为: 半诚实模型、恶意模型
- SGX是Intel架构新扩展, 在原有架构上增加了: 一组新的指令集; 内存访问机制
- 可信操作系统启动包括两种情况: Trusted OS 首先启动; Trusted OS 按需启动

选择题

- SGX和TrustZone对比, 优势为A支持虚拟化技术、容器技术B将系统可信计算基缩小到CPU D通过内存泄漏攻击获取关键信息难度更大

术语解释

- 同态加密：在密码学中，记加密操作为 E ，解密操作为 D ，明文为 m ，加密得 c ，即 $c = E(m)$ ， $m = D(c)$ 。已知针对明文有操作 f ，针对 E 可构造 F ，使得 $F(c) = E(f(m))$ ，这样 E 就是一个针对 f 的同态加密算法。
- 安全多方计算 (Secure Multi-party Computation)：由姚期智在 1982 年提出，主要针对的问题是如果没有可信第三方的情况下，安全地对参与方的输入进行计算，同时不向参与方展示除计算结果外的任何信息。
- 零知识证明：不会将证据泄露给验证者的知识证明。
- 混淆电路：混淆电路 (GC) 协议是一种加密协议，可实现两方安全计算，其中两个互不信任的参与方可以在没有可信第三方存在的情况下共同评估其私有输入的函数。

简答题

- TEE, SE, Rich OS 对比：
 - Rich OS：普通操作系统（如 Linux/Windows/Android），功能丰富、运行应用多，隔离性弱，攻击面大。
 - TEE (Trusted Execution Environment)：CPU/芯片内的受信任执行环境（如 TrustZone/SGX），提供软硬件结合的隔离与密钥保护，适中资源与较好性能。
 - SE (Secure Element)：独立的安全芯片/智能卡，抗篡改强、用于高安全密钥存储和敏感操作，但资源最受限、开发部署成本高。
 - 共同点：都用于保护敏感数据与执行可信逻辑；可组合使用（Rich OS 提供服务界面，TEE/SE 做可信操作）。
- Paillier 算法相关：
 - 为什么 Paillier 是语义安全的？基于决策复合剩余性 (DCR) 假设：在不知道私钥的情况下，观察到 $g^m r^N$ 与随机元素无法区分，因此攻击者不能从密文推断明文 $\rightarrow$ IND-CPA (语义安全)。
 - 为什么密文长度约为明文长度的 2 倍？明文 $m \in \mathbb{Z}_N$ (模 N ，长度约 $\log_2 N$ 位)；密文 $c \in \mathbb{Z}_{N^2}^*$ (模 N^2 ，长度约 $\log_2 N^2 = 2\log_2 N$)，所以密文位长约为明文的两倍。
 - 同一明文每次加密不同但能正确解密的证明：
 - 加密：选随机 $r \in \mathbb{Z}_N^*$ ，计算 $c = g^m r^N \bmod N^2$ 。不同 $r \rightarrow$ 不同 c 。
 - 解密 (关键步)：计算 $c^\lambda \bmod N^2 = (g^m r^N)^\lambda \equiv g^{m\lambda} \pmod{N^2}$ (因为 $(r^N)^\lambda \equiv 1$)，用函数 $L(u) = (u - 1)/N$ 得到与 m 线性相关的值，除以常数 $L(g^\lambda)$ 得到 m 。
 - 因此随机 r 只改变掩盖项 r^N ，不影响通过 c^λ 提取明文的过程，解密仍返回原 m 。
 - 同态性证明：
 - 若加密算子 E 在密文空间有运算 $\circ$ ，使得对任意明文 m_1, m_2 ：

$$D(E(m_1) \circ E(m_2)) = m_1 * m_2$$
，则称 E 对明文运算 $*$ 是同态的。
 - RSA 加密： $E(m) = m^e \bmod N$ 。两密文乘积：
 $E(m_1)E(m_2) = m_1^e m_2^e = (m_1 m_2)^e \bmod N$ 。解密得 $(m_1 m_2)^{ed} \equiv m_1 m_2 \bmod N \rightarrow$ RSA 对乘法同态。
 - Paillier 加密： $E(m) = g^m r^N \bmod N^2$ 。乘积：
 $E(m_1)E(m_2) = g^{m_1} r_1^N \cdot g^{m_2} r_2^N = g^{m_1+m_2} (r_1 r_2)^N \bmod N^2$ 。该乘积即为对明文

$m_1 + m_2$ 的合法加密，解密得到 $m_1 + m_2 \bmod N \rightarrow$ Paillier 对加法同态。

第七章

填空题

- 具体应用中，隐私 即数据所有者不愿意披露的信息，包括敏感数据以及数据所表征的特征
- s 表示敏感数据， S_k 表示攻击者在背景知识 K 下揭露敏感数据 s ，披露风险为 $r(s, K) = Pr(S_k)$
- 对任意相邻数据库，任何可能的带噪中间件 S ，提供 ϵ -差分隐私的算法 M 必须满足： $Pr[M(D_1) = S] \leq \exp(\epsilon) \cdot Pr[M(D_2) = S]$
- ϵ -本地化差分隐私： $Pr[M(t) = t^*] \leq e^\epsilon \times Pr[M(t') = t^*]$
- RAPPOR 算法是谷歌提出的基于随机响应的一个差分隐私算法，用于收集用户数据并保证用户隐私。

选择题

- 常见隐私保护模型：A.k匿名 B.l-多样化 C.t相近
- 中心化差分隐私领域基础机制：A拉普拉斯机制
- 差分隐私为了保证机器学习模型的隐私保护，添加随机扰动的方式：A输入扰动 B中间参数扰动 C目标扰动 D输出扰动

术语解释

- 抑制：管理员修改识别字段。他可能会抑制这些识别字段，把表中的字段完全删除。
- 泛化 (Generalization)：为了更好地实现效用和隐私之间的平衡，管理者可能会泛化而不是抑制标识符。这意味着他将改变而不是删除标识符值以增强隐私，同时保持数据的实用性。

简答题

- k匿名低于记录链接攻击：
 - k-重匿名 (k-anonymity)：通过泛化/抑制，使得每条记录在准标识符 (QID) 上与至少 $k-1$ 条记录相同。
 - 抵御原理：攻击者即使知道某人 QID 信息，也只能将其与至少 k 条候选记录匹配，无法唯一确定，从而抵御记录链接攻击。
- l-多样化抵御属性链接攻击：
 - l-多样化 (l-diversity)：在每个等价类中，敏感属性至少有 l 种“充分不同”的取值。
 - 抵御原理：即使攻击者定位到某个等价类，也无法推断出敏感属性，因为存在至少 l 种可能，从而抵御属性链接攻击。
- 差分隐私机制比较：
 - 拉普拉斯机制：在查询结果上加入服从 $Laplace(0, \Delta f / \epsilon)$ 分布的噪声。适合精确的 ϵ -差分隐私，常用于数值查询。

- 高斯机制：在结果上加入服从 $\text{Gaussian}(0, \sigma^2)$ 的噪声。适合 (ϵ, δ) -差分隐私，更灵活，常用于统计学习。
- 指数机制：对离散输出集合，按效用函数分数加权，概率性选择输出，满足差分隐私。适合非数值结果的选择问题（如推荐、分类）。
- CDP（中心化）与 LDP（本地化）：
 - CDP 假设有可信的中心化数据持有方；LDP 不依赖信任，隐私更强，但数据可用性和准确度相对下降。
- 随机响应与一元编码基本原理：
 - 随机响应（Randomized Response）：用户对真实答案进行随机翻转，例如“是/否”问题中以某个概率回答真值，以另一概率回答反值。保护个体隐私，同时统计上仍可恢复总体分布。
 - 一元编码（Unary Encoding, UE）：将用户的真实取值编码为一个一热向量（one-hot），然后随机翻转其中的比特位，从而保护隐私。区别：UE 是随机响应在多值域上的推广，适用于多选或分类场景。
- RAPPOR 过程：
 - 编码：将用户敏感数据映射为独热编码。
 - 扰动阶段一：固定随机扰动，保证长期隐私。
 - 扰动阶段二：在每次上报前再次随机扰动，防止多次收集攻击。
 - 收集与聚合：服务端收集大量扰动后的数据向量。
 - 统计估计：通过概率反演和聚合，恢复总体分布，而个体隐私仍得到保护。